

7 Pentesting Tools You Must Know About

What are Pentesting Tools?

[Penetration testing](#) (also known as pentesting) is a cybersecurity technique used by organizations to identify, test, and remediate vulnerabilities and weaknesses in their security controls.

Penetration testing tools are used as part of penetration testing to automate certain tasks, improve testing efficiency, and uncover issues that are difficult to discover with manual analysis techniques alone. Once threats and vulnerabilities are assessed, penetration testers provide a report that can help the organization address the identified risks to improve their cyber defenses.

Pentesting tools are important for security testing in modern, large-scale IT environments. They enable discovery of assets in complex, hybrid environments, and can help testers evaluate systems against security benchmarks and compliance requirements. While no tool can substitute for the ingenuity of a talented pentester, tools can expand and deepen the reach of penetration tests, helping them achieve a better result.

Types of Penetration Testing Tools

A penetration testing toolkit should include a variety of tools. Here are several common categories of tools:

- **Port scanners**—identify open ports on the system. This helps testers identify the operating system and applications currently running on a network they are trying to access. Port scanners are used in reconnaissance and can provide ideas for potential attack vectors.
- **Vulnerability scanners**—search for known vulnerabilities in servers, operating systems, and applications, as well as misconfigurations that can be exploited in a test. Reports provided by vulnerability scanners help penetration testers select an exploitable vulnerability that will grant them initial access to the system.

- **Network sniffer**—monitors information in network traffic, including its source, destination, the devices communicating on the network, protocols and ports used. This can be useful for checking if data is encrypted and identifying communication paths that can be exploited during the penetration test.
- **Web proxy**—allows penetration testers to intercept and modify traffic between their browser and an organization's web servers. This makes it possible to detect hidden form fields and other HTML features that might enable attacks like cross-site scripting (XSS) or cross-site request forgery (CSRF).
- **Password cracker**—password hashing is a common target for attackers as a means of escalating privileges on a target system or network. Password crackers allow penetration testers to determine if an organization's employees are using weak passwords that pose a risk of abuse.

Best Tools for Penetration Testing Experts

1. Kali Linux

License: open source

GitHub Repo: N/A

Kali Linux is an operating system that facilitates penetration testing, security forensics, and related activities. It is a Linux distribution based on Debian, provided as open source and maintained by Offensive Security.

Kali Linux includes the following tools (some of which are covered separately in our list):

- **Armitage**—graphical network attack management tool
- **Nmap**—port scanner
- **Wireshark**—packet analyzer
- **Metasploit**—penetration testing framework with thousands of exploit modules
- **John the Ripper**—password cracker
- **sqlmap**—automated SQL injection and database import
- **Aircrack-ng**—software suite for wireless LAN penetration testing
- **OWASP ZAP**—web application security scanner
- **Burp suite**—application security testing

2. Burp Suite

License: free and paid options

GitHub Repo: <https://github.com/PortSwigger>

Burp Suite is a suite of application security testing tools developed by Portswigger. The suite includes the popular web proxy Burp Proxy.

Burp Proxy allows penetration testers to conduct man-in-the-middle (MitM) attacks between a web server and a browser. They allow inspection of network traffic, which can help detect and exploit vulnerabilities and data leaks in web applications.

Key features of Burp Suite include:

- Using a dedicated client to perform manual testing for out-of-band vulnerabilities.
- Testing and confirming clickjacking attacks with specialist tooling.
- Assessment of token strength by testing quality of randomness in token data items.
- Deep manual testing, making it possible to see reflected or stored inputs to test for XSS and similar vulnerabilities.
- Records results of automated attacks and enables testers to fine-tune them in subsequent attacks.
- Enables faster brute-forcing and fuzzing with custom sequences of HTTP requests containing multiple payload sets.
- Constructs CSRF exploits, making it possible to generate exploit HTML demonstrating a CSRF attack for any suitable request.

3. Wireshark

License: open source

GitHub Repo: <https://github.com/wireshark/wireshark>

Wireshark is a network monitoring solution that captures and analyzes network traffic across a variety of communication channels. Penetration testers can automatically read real-time data from different types of networks, such as Ethernet, token ring, loopback, and asynchronous transfer mode (ATM) connections.

IT professionals can capture packet data from live networks and analyze packets in the captured files through a graphical user interface (GUI). Wireshark allows users to modify captured files using command-line switches, apply complex filters, and create plugins to analyze new protocols. It also enables creating modelines to alter configuration files in real time.

Wireshark enables penetration testers to investigate security issues on a network, identify elements of the network that are malfunctioning and could be exploited in an attack, and detect protocol implementation or configuration errors.

Additional features include:

- Data encryption
- Compliance management capabilities
- Server monitoring and alerting
- Data import/export

4. John the Ripper

License: open source

GitHub Repo: <https://github.com/openwall/john>

John the Ripper is a free password cracking tool that supports 15 operating systems, including 11 from the Unix family, DOS, Win32, BeOS, and OpenVMS.

The tool is customizable password cracker with many options for password testing, including:

- Auto-detection of password hash types.
- Wide support for encrypted password formats including Unix crypt hashes, Kerberos AFS tokens, and Windows LAN Manager (LM) hashes.
- Ability to crack password encryption based on DES, MD5, Blowfish, and MD4.
- Support for password hashes and passwords stored in databases and directory systems such as LDAP and MySQL.

5. Hashcat

License: open source

GitHub Repo: <https://github.com/hashcat/hashcat>

Hashcat is a popular password cracker able to crack highly complex representations. It does this by combining multiple highly effective password cracking methods.

The main technique used by Hashcat is manipulating hash keys generated by algorithms like MD5, SHA, WHIRLPOOL, RipeMD, NTMLv1, and NTMLv2. These are one-way functions which are difficult to reverse.

Hashcat converts readable data to a hashed state, and attempts a variety of methods including dictionaries, rainbow tables, and brute force techniques, to identify a hash that matches a discovered password hash and thus crack the password.

6. Nmap

License: open source

GitHub Repo: <https://github.com/nmap/nmap>

Nmap is a free tool used for network security assessment and investigation. It supports Linux, Windows, Solaris, HP-UX, BSD variants including Mac OS, and AmigaOS. It provides both a CLI and GUI interface.

Penetration testers can use Nmap to understand which hosts they can access on a network, what services they expose, which frameworks they are running, and what types of bundled tunnels or firewalls are in use.

Common tasks that can be performed via Nmap include:

- Discovering network assets
- Checking for open ports
- Overseeing network administration tasks
- Observing host uptime

7. Invicti

License: commercial

GitHub Repo: N/A

Invicti is provided both as a cloud service and on-premise solution. It provides automated application vulnerability assessment, which can help penetration testers identify exploitable vulnerabilities in websites.

Invicti runs a Chrome-based crawler to find vulnerabilities in a variety of web assets, including dynamic web applications, HTML5 websites, and single page applications, and can also scan authenticated websites by submitting credentials, without having to configure a black box scanner.

Key features include:

- Asset discover and detection
- Scheduled vulnerability tests
- Detection of vulnerabilities related to OWASP Top 10 attacks
- Database security auditing
- Identifying vulnerable versions of languages and web frameworks
- Creates detailed reports that can form part of a penetration test report

Penetration Testing with HackerOne

HackerOne Pentest is a service that provides management and tracking of the entire pentesting process with automated workflows and an intuitive user experience. It provides real-time visibility into the testing process with on-demand results that can be acted on prior to delivery of the final report.

HackerOne matches the needs of the organization with the specialized skills and talents of a global network of fully vetted ethical hackers. Each test includes dedicated technical engagement managers to keep projects on track and ensure delivery of high quality results. HackerOne's offering supports security assessments to identify infrastructure misconfigurations across web, mobile, network, API, and desktop assets.

Key capabilities:

- Access reports securely and manage vulnerability submissions from a single cloud dashboard
- Scope and launch pentests with speed and efficiency
- Track vulnerability trends and view historical data to analyze patterns across assessments
- Communicate directly with testers to make collaboration easy
- Rotate testers to get new perspectives
- Get real-time alerts as vulnerabilities are detected by the pentesters
- Engage testers for retesting to validate that vulnerabilities were fixed
- Receive a final report with recommendations, the assessed scope, tester profiles, vulnerability details, remediation results, and more
- Integrate with internal ticketing systems to seamlessly manage backlogs and assign reports to team members via your preferred workflow

Learn more about [HackerOne Pentest](#)

Company

Leadership

Careers

Knowledge

Center

Application Security

Resources

Blog

Documentation

Partners

Penetration Testing

Leaderboard

Newsroom

Cloud Security

Partner Portal

Contact Us

Hacking

Resources

Contacted
by a
hacker?



Cybersecurity

Attacks

DevSecOps

Cookie Preferences

Policies

Terms

Privacy

Security

©2025 HackerOne All rights reserved.

Trust